SWARMA

Люди и их агенты

Потребительский мессенджер на платформе Swarma

24 октября 2026 года

Продуктовая гипотеза и план хакатона · закрытый рабочий документ

Содержание

0 Один фундамент, разные продукты 3
0.1 Как это представить 3
0.2 Что здесь является планом 3

1 Зачем два транспорта 4
1.1 Одна личность, два пути доставки 5

2 Какой XMPP нужен продукту 6
2.1 Чего не даёт паролькless-вход 7

3 Из чего собирается мессенджер 8
3.1 Готовые примитивы и отсутствующие стыки 8

4 Первый запуск и привязка телефона 10

5 Новый помощник без общего секрета 11

6 Разговор и действие с подтверждением 12

7 Доступ к календарю близкого человека 13

8 Незнакомец сначала просит контакт 14

9 Отозвать доступ и потерять телефон 15

10 Доверие словами пользователя 16
10.1 Что видит сервер 16
10.2 Подписи через границу транспорта 16

11 Что собираем на хакатоне 17
11.1 Демо на шесть с половиной минут 17
11.2 Риски и fallback 18

12 После демо: продукт и решения 19
12.1 Вопросы оператору 19

0 Один фундамент, разные продукты

Swarma — платформа для агентов, которыми управляют люди. Она связывает среду исполнения, ключи, полномочия и проверку сообщений. Потребительский мессенджер — один из продуктов поверх неё: человек пишет близким, своему помощнику или агенту другого человека. Это не перенос терминала в телефон. Основной экран показывает разговор и решения, а сырой вывод сессии остаётся отдельным уровнем для владельца.

У платформы два продуктовых направления. Для бизнеса — фабрики автоматизации: разработка и другие процессы, командные пространства и корпоративные интерфейсы через каналы Matrix. Для человека — небольшой XMPP-клиент, где рядом с людьми живут постоянные помощники: календарь, документы, бытовые задачи. Общая часть — проверяемая личность и ограниченные права, а не одинаковый интерфейс. предложено

0.1 Как это представить

Подача	В чём сила	Какое ожидание надо ограничить
Платформа и два продукта	Понятно, кому продаём: автоматизация бизнесу, помощники человеку; модули переиспользуются	Два интерфейса не означают две независимые системы доверия
Одна сеть доверия, много интерфейсов	Объясняет общение семьи, компании и агентов через разных провайдеров	Федерация ещё не означает готовую сеть или право писать каждому
Операционная среда для агентов	Объясняет учётки ОС, ключи, запуск и устойчивые роли	Это метафора, а не обещание заменить ОС телефона или компьютера

Для хакатона предлагается первая подача. Демонстрация начинается с понятного вопроса: «Есть ли свободное время в пятницу?» Затем показывает, почему агент близкого человека ответил только в пределах разрешения. Платформа объясняет проверяемое поведение, а не заслоняет продукт. предложено

0.2 Что здесь является планом

Модули платформы уже дают часть нужных примитивов. Потребительский клиент, XMPP-адаптер, pairing и сквозная сборка продукта не объявляются готовыми. Далее каждая новая связка — предложение; таблица «Что собираем на хакатоне» отделяет работающий путь от имитации. Все адреса с доменом `example.test` вымышлены. Точные форматы определяют спецификации модулей: продуктовая схема их не расширяет.

1 Зачем два транспорта

Транспорт доставляет сообщение, но не выдаёт полномочие. Matrix удобен там, где работа организована вокруг комнат, участников и обсуждений. XMPP предлагается для личного разговора и небольших групп. Это выбор поверхности продукта, а не утверждение, что один протокол умеет команды, а другой — только переписку. Агентский трафик может идти по обоим. предложено

Ось	Matrix	XMPP
Команда и разговор	Комнаты, Spaces, отношения событий и threads; удобная исходная модель командного пространства	Личные чаты, roster, группы MUC; MIX предлагает каналы. Командную навигацию и threads надо выбирать вместе с клиентом
Федерация	Homeservers обмениваются событиями и состоянием комнат	Серверы разных доменов маршрутизируют сообщения. Нужны совместимые расширения и политика доступа
E2EE	Olm/Megolm; cross-signing связывает устройства через ключи пользователя	OMEMO — многопользовательское и многоустройственное шифрование; его устройства требуют своей проверки
Аккаунт на ключе	Вход и E2EE-личность разделены; существующий JWT-вход агента не равен подписи действия	JID — адрес, не публичный ключ. Вход без пароля требует выбранного SASL-механизма и привязки ключа к аккаунту
Сервер и эксплуатация	Состояние комнат, история, федерация и crypto-интеграция задают объём эксплуатации	Набор модулей сервера задаёт объём: PEP, архив, группы, upload, push. «XMPP легче» без одинаковой нагрузки не измерение
Mobile push	Есть Push Gateway API; содержание уведомления зависит от настроек клиента	XEP-0357 описывает серверный путь push; связь с APNs и поведение iOS проверяются отдельно
Клиенты	Есть Element и другие клиенты с разными наборами возможностей	Есть мобильные и desktop-клиенты; совместимость выбранного OMEMO-профиля проверяется попарно
Мосты	Application Service API позволяет интеграции; доступ к plaintext меняет границу доверия	Component Protocol подключает сервис к серверу, но сам не даёт OMEMO и не сохраняет E2EE автоматически

Основания: Matrix Client-Server API, Server-Server API, каталог клиентов Matrix, каталог XMPP и расширения из следующей главы. Сравнение не квалифицирует конкретный сервер или мобильную библиотеку.

1.1 Одна личность, два пути доставки

Внутри одного роя a2a выбирает провайдер Matrix для командной комнаты и XMPP для личного разговора. Подписанное прикладное содержимое проходит через общий verifier; адаптер не меняет подписанные байты. Оболочки, адреса и E2EE-сессии у транспортов разные. Сопоставление адресата и аудитории с подписанным контекстом — явная обязанность адаптера. **предложено**



Рис. 1.1. Два транспорта сходятся у одной проверки полномочий

Это не обязательный мост всех комнат друг в друга. Новый маршрут не переносит право читать историю, а повторная доставка по двум носителям не должна повторно исполнять действие. Для MVP — один выбранный маршрут на разговор. Копирование между носителями остаётся выключенным, пока не проверены аудитория, защита от повторов и сохранение точных байтов. **предложено**

2 Какой XMPP нужен продукту

Недостаточно выбрать сервер с надписью «поддерживает XMPP». Перед реализацией команда фиксирует версии сервера, библиотек и расширений, затем проверяет одну совместимую комбинацию. Ниже — предлагаемый профиль, а не протокол собственной разработки. Статус XEP не доказывает поддержку в выбранном клиенте. предложено

Возможность	Конкретное расширение	Место в MVP и обязательная проверка
Шифрование	XEP-0384 OMEMO, 0.9.1, Experimental	Основной путь. Зафиксировать общий профиль; проверить новое устройство, offline-доставку и смену ключа без молчаливого доверия
Группы	XEP-0045 MUC	Выбрать для маленькой закрытой группы. Проверить режим членства, удаление участника и список получателей OMEMO
Альтернатива группам	XEP-0369 MIX	После MVP; не считать взаимозаменяемым с MUC. Проверить сервер, клиент и сочетание с OMEMO до включения
Ключи устройств	XEP-0060 PubSub, XEP-0163 PEP	Получение OMEMO bundles и списков устройств. Проверить федеративное чтение, недоступность и смену списка
История	XEP-0313 MAM, 1.1.3	Архив зашифрованных сообщений. Проверить возврат после offline; наличие архива не даёт новому устройству старые ключи
Несколько клиентов	XEP-0280 Carbons, 1.0.1	Доставка копий на свои ресурсы; проверить дубли и E2EE для каждого допущенного устройства
Уведомления	XEP-0357 Push, 0.4.1, Deferred	Проверить сервер, push-сервис и iOS в фоне. При неготовности — явно foreground-only демо; никаких секретов в preview
Вложения	XEP-0363 HTTP Upload, 1.2.0	Вне основного демо. Проверить клиентское шифрование файла и передачу ключа внутри E2EE: upload сам файл не шифрует
Серверный стык	XEP-0114 Component Protocol, 1.6	Кандидат для bridge-компонента. Проверить аутентификацию и маршрутизацию; права компонента не заменяют подписи агентов

Возможность	Конкретное расширение	Место в MVP и обязательная проверка
Вход на ключе	XEP-0178 SASL EXTERNAL, 1.2	Кандидат с клиентским сертификатом и PKIX. Проверить связь JID с ключом, provisioning, отзыв и поддержку в iOS/сервере

Для первой сборки можно оставить мост обычным XMPP-клиентом на станции, а component-стык отложить. Если используется XEP-0114, серверный компонент только маршрутизирует; OMEMO завершается в доверенном локальном адаптере агента. Перенос расшифровки на общий сервер меняет модель и должен называться другим вариантом продукта. предложено

2.1 Чего не даёт паролbless-вход

Passkey, подпись `swarm-envelope/2`, TLS-сертификат и OMEMO-ключ — разные механизмы. SASL EXTERNAL не означает автоматической поддержки WebAuthn или ключа Ed25519 ключника. XEP-0388 описывает расширяемый SASL-профиль, а XEP-0440 — объявление channel binding; ни один не является готовым входом «любым ключом Swarma».

Пока общий путь не проверен, аккаунты для демонстрации создаются вручную, сертификаты настраиваются отдельно. На экране явно написано: «Вход подготовлен для демо». Нельзя переименовать пароль или JWT в key-based аккаунт и считать требование выполненным. Выбор окончательного входа остаётся открытым. предложено

3 Из чего собирается мессенджер

Клиент — окно разговоров и решений. Станция — место, где работают агенты и проверяются права на инструменты. Сервер — доставка и хранение шифротекста. Ключник — отдельная служба подписей; кипер — корневой агент, который координирует помощников. Эти две роли не смешиваются.

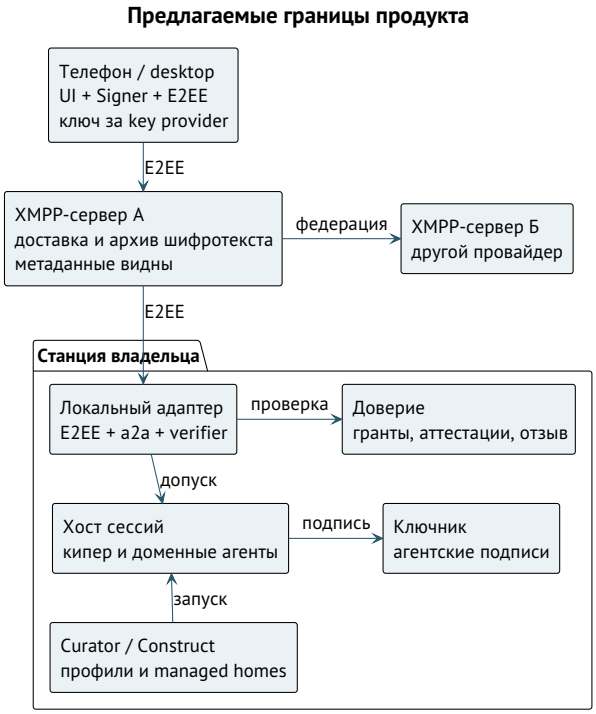


Рис. 3.1. Граница сервера проходит снаружи расшифровки и исполнения

В целевой схеме телефон и локальный XMPP-адаптер являются E2EE-концами. Агент получает plaintext после допуска; его модельный провайдер тоже может его получить. Обещание шифрования относится к транспортным серверам, а не к сокрытию данных от исполняющего агента или его модели. предложено

3.1 Готовые примитивы и отсутствующие стыки

Состояние модулей ниже дано на октябрь 2026 года. Квалификация отдельного модуля не означает готовность их потребительской сборки.

Часть	Что даёт платформа	Чего нет в готовом продукте; допущение хакатона
Клиент iOS/desktop	Проект Swarm Signer предусматривает core правил и key provider; P-256 устройства в Secure Enclave	Встраиваемый XMPP-клиент и весь UI ещё собираются. Начать с iOS и desktop-панели на станции; общий core — явная зависимость, не готовая библиотека

Часть	Что даёт платформа	Чего нет в готовом продукте; допущение хакатона
Ключник	Агентские ключи, namespace `swarma-msg` с purpose 4, аттестации purpose 5; multi-UID квалифицирован	Проверить точный вызов из нового bridge. В демо заранее зарегистрировать тестовые личности; не отдавать секрет модели
Регистратор	JWT-вход агентов на homeserver	Это не готовый XMPP SASL. Временно ручной provisioning; пользовательский вход на ключе квалифицировать отдельно
Брокер учётных данных	Один владелец логинов подписок моделей и временная политика выдачи	Не путать с аккаунтом мессенджера. Демо использует подготовленный доступ к модели без копирования логинов в клиент
Менеджер пользователей	Станции, отдельная учётка ОС на агента	Provisioning с телефона ещё надо связать. В демо учётки подготовлены вручную, запуск использует их явно
Curator, curator-run, Construct	Профили, управляемые дома и запуск	Разрешённые профили заранее подготовлены. Не обещать готовую кнопку самообслуживания для любого нового помощника
Хост сессий	Нативный мост сессий	Проверить ввод, вывод и восстановление конкретного harness через XMPP; начать с одного агента и одного адаптера
a2a	Абстракция транспорта, сегодня Matrix	XMPP-провайдер и сопоставление аудитории ещё нужны; демо сохраняет ту же границу verifier перед доставкой
Слой доверия	Контракт подписанных сообщений задаёт `swarm-envelope/2`, `grant/1`, `operator-act/1`, `attestation/1`, `revocation/1`	Не считать план совместимости уже встроенным enforcement. Если общего verifier нет, эффект блокируется или показывается как симуляция
XMPP-сервис	Стандартный федеративный протокол и расширения	Выбрать сервер и библиотеки. Сначала свой закрытый сервер; два домена — отдельный проверяемый этап

Signer core отделяется от UI, хранения E2EE-секретов и аппаратной подписи. Исследовательская рекомендация Rust/UniFFI с Matrix Rust SDK не утверждает язык ядра и не выбирает библиотеку OMEMO. Для XMPP требуется отдельная квалификация. На хакатоне можно сократить число платформ, но нельзя скрыть отсутствие проверяющего ядра красивым Face ID-экраном. **предложено**

4 Первый запуск и привязка телефона

Цель — связать телефон с собственным корнем, а не просто войти на сервер. QR передаёт данные начала привязки; сверка SAS помогает заметить подмену канала. Ни QR, ни совпавшие emoji сами по себе не создают грант. Точный протокол pairing, свежесть приглашения и доказательство владения ключом ещё надо закрепить. **предложено**

1. На станции подготовлены ключник, корневой агент и аккаунт `keeper@example.test`. Установщик показывает, какую станцию человек связывает с телефоном.
2. Телефон создаёт отдельный ключ устройства через key provider. В рассматриваемом Apple-пути это P-256/ECDSA; закрытый ключ не передаётся ядру правил.
3. Владелец сканирует QR со своей станции. Обе стороны показывают SAS/emoji для одной попытки; человек сверяет их по доверенному локальному каналу.
4. При несовпадении или отмене попытка закрывается без аттестации. При совпадении владелец отдельно удостоверяет ключ и его назначение через корневую церемонию.
5. Телефон закрепляет доверенный корень. Для OMEMO проверяется и удостоверяется каждый fingerprint устройства; аналог Matrix cross-signing не предполагается.
6. Интерфейс показывает корневого агента и выданные права. Первый тестовый разговор идёт только после проверки цепочки и готовности E2EE.

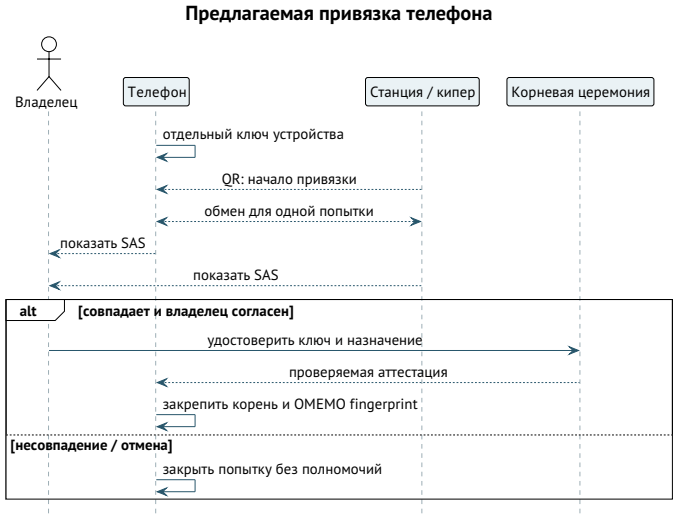


Рис. 4.1. QR начинает попытку; доверие появляется после сверки и удостоверения

Первое сообщение: «Покажи доступных помощников». Положительный результат — ответ собственного кипера с проверенным происхождением. Отрицательный контроль — подменённый QR или другая SAS: чат не получает статус привязанного, никаких полномочий и ключей чужой стороне не добавляется.

Допущение хакатона. Один телефон и одна подготовленная станция; корневая подпись выполняется вручную. Если SAS ещё не реализован, показываем ручную сверку полного fingerprint и называем это ручным pairing. Слайд с emoji нельзя показывать как работающую защиту от подмены. **предложено**

5 Новый помощник без общего секрета

Человек просит: «Добавь помощника календаря». Кипер координирует создание, но не выдаёт себе право создавать произвольные аккаунты. Получается отдельная личность `calendar@example.test`, отдельная учётка ОС и ограниченный набор инструментов. предложено

1. Клиент показывает профиль помощника и запрашиваемые права: например, читать только демонстрационный календарь. Расширение прав требует отдельного подтверждения владельца.
2. Кипер передаёт допущенную заявку компонентам provisioning. Для демо учётка ОС и профиль могут быть подготовлены заранее.
3. Ключник регистрирует личность с привязкой к учётке и поколению; использует отдельный производный агентский ключ. Мастер-секрет и закрытый ключ не попадают в промпт.
4. Регистратор или ручной шаг создаёт адрес XMPP; локальный адаптер получает свой E2EE-контекст. Адрес и ключ личности связываются проверяемой записью, а не совпадением имён.
5. Curator запускает агента с выбранным профилем и managed home; хост сессий привязывает ввод и вывод к bridge.
6. Телефон получает проверяемую цепочку нового агента через уже доверенный канал и проверяет её. Чат появляется только после допуска, а не по любому входящему сообщению с именем «Календарь».

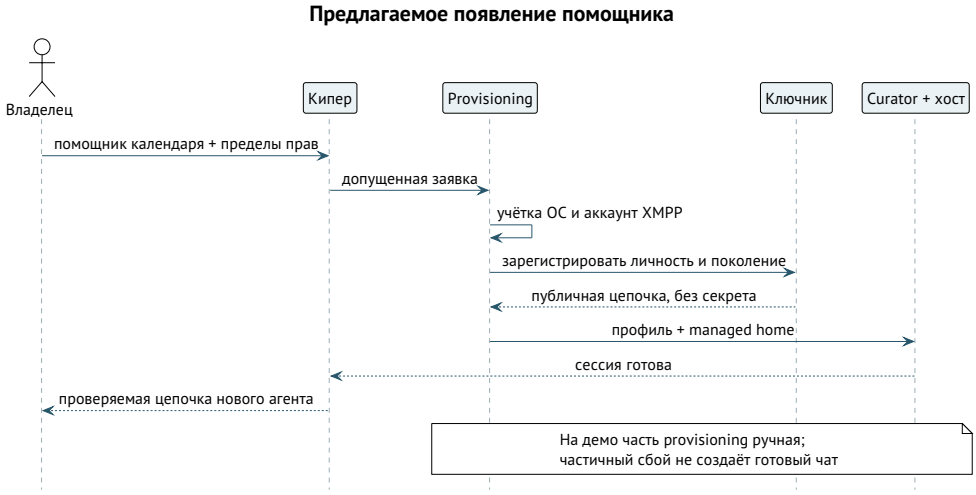


Рис. 5.1. Создание личности, аккаунта и сессии — отдельные операции

Деривация упрощает выпуск ключей у ключника, но не заменяет аттестацию и грант. Она также не является настройкой OMEMO: для шифрования нужны собственные устройства, bundles и сессии. Формулу деривации, численные пределы и новый формат цепочки здесь не вводим.

Контроль отказа. Повтор заявки не создаёт второго помощника; неподтверждённый профиль или чужая учётка не получают ключ. При частичном provisioning клиент показывает «не готов», а не доступный чат. Порядок компенсации и идентификатор идемпотентности должны быть закреплены контрактом; на хакатоне незавершённый экземпляр отключают вручную. предложено

6 Разговор и действие с подтверждением

Реплика «Какие у меня встречи?» и команда «Удали встречу» выглядят в чате похоже, но проходят разные правила. Обычное сообщение может вызвать только разрешённое чтение. Изменение появляется как карточка точного действия: что меняется, у кого и на какой цели. Модель не выбирает себе уровень полномочий. предложено

1. Человек отправляет обычную реплику. Клиент защищает её E2EE, а bridge проверяет происхождение и право на общение.
2. Агент читает данные через ограниченный инструмент. Для запроса «покажи свободное время» не требуется подписывать весь будущий разговор с Face ID.
3. Если нужен критический эффект, агент предлагает действие, но не исполняет его. Signer показывает человеку точный объект и изменение.
4. Человек подтверждает через Face ID. Key provider подписывает подготовленные байты ключом устройства; отказ или отмена ничего не отправляет к исполнению.
5. Verifier проверяет подпись, назначение ключа, цепочку, грант, свежесть, отзыв, адресата и повторы. Исполнитель повторяет необходимую проверку непосредственно перед эффектом.
6. В чат приходит отдельный результат исполнения. «Доставлено» означает доставку, а не успешное удаление или запись в календарь.

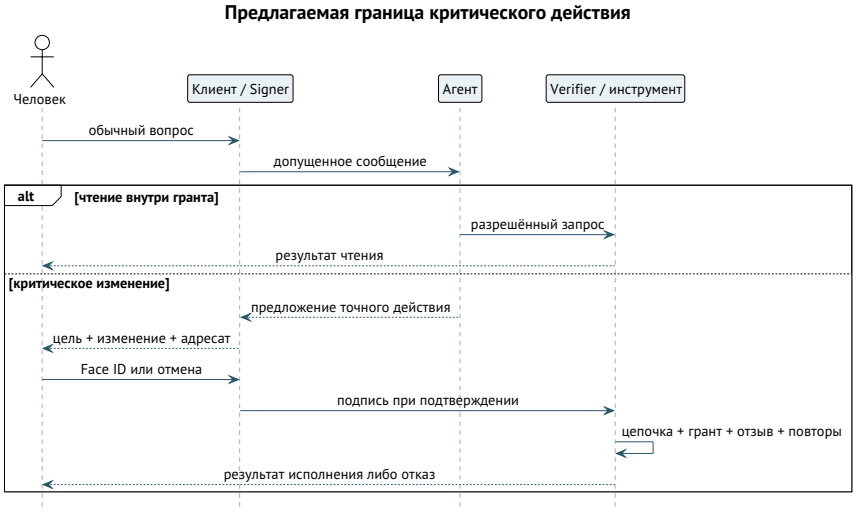


Рис. 6.1. Обычное чтение и критическое изменение идут разными ветками

Secure Enclave в этом пути использует P-256/ECDSA; агентские подписи — Ed25519. Обычная подпись P-256 сама не доказывает удалённому проверяющему факт Face ID. Проверяемая связь присутствия с точным действием требует контракта и векторов. При отсутствии нужного доказательства расширяющий или критический эффект закрыт.

Контроль отказа. Отмена Face ID, изменение цели после показа, повтор подтверждения или отсутствие гранта не меняют календарь. Рядом проверяется положительный путь ровно того же действия с допустимыми условиями. На демо можно использовать локальный тестовый календарь; кнопка с имитацией Face ID должна быть явно подписана как симуляция. предложено

7 Доступ к календарю близкого человека

У двух владельцев разные корни доверия. Семейная связь не делает их агентские среды общей учёткой. Человек А спрашивает агента календаря человека Б: «Есть ли свободное время в пятницу?» Ответ может содержать свободные интервалы, но не названия встреч. предложено

1. Владельцы устанавливают контакт и сверяют ключи. Адрес `calendar-b@example.test` остаётся адресом; право выводится из проверенного ключа и цепочки.
2. Человек Б открывает карточку гранта: получатель, календарь, чтение свободных интервалов, срок. Создание событий и дальнейшая передача права не включены.
3. Подтверждённый грант публикуется в реестре. На телефоне появляется понятное разрешение «может узнавать свободное время», а не «полный доступ к агенту».
4. Человек А или его допущенный агент подписывает запрос своим ключом. Если спрашивает агент А, грант должен разрешать именно ему или допустимую цепочку делегирования; родство этого не заменяет.
5. На стороне Б детерминированная проверка устанавливает область и срок. Ограниченный адаптер календаря возвращает только свободные интервалы.
6. Ответ подписывается, шифруется для допущенных получателей и возвращается в тот же разговор. Другой чат не получает историю или детали календаря.



Рис. 7.1. Семейный грант разрешает ответ о занятости, но не изменение календаря

Узкий адаптер важен: если модель сначала увидела весь календарь, обещание «названия встреч не раскрываются» уже слабее. Для MVP нужен отдельный вызов только свободных интервалов, а не инструкция модели скрыть лишнее. предложено

Контроль отказа. Тот же собеседник просит название встречи или её удаление — отказ без выдачи деталей и без записи. Просроченный или отозванный грант также закрывает чтение. Положительный контроль — разрешённый вопрос о свободном интервале. Семейная комната и приглашение в MUC сами по себе календарь не открывают.

8 Незнакомец сначала просит контакт

Whitelist действует до попадания сообщения в рабочую сессию агента. От неизвестного ключа не принимаются ни поручения, ни произвольные файлы, ни просьбы модели «самой решить, можно ли ответить». Однако запрос контакта нужен продукту: для него предлагается отдельный ограниченный канал, который не является разговором с агентом. предложено

1. `visitor@example.test` отправляет запрос контакта: представиться и попросить конкретный вид взаимодействия. Он ещё ничего не может спросить у календаря.
2. Входной компонент ограничивает частоту и размер запросов. Тело не попадает в промпт и не запускает инструменты; клиент показывает его как неподтверждённые данные.
3. Владелец отвергает запрос или сверяет ключ доверенным способом. Display name, домен сервера и фраза «меня одобрил ваш партнёр» не устанавливают личность.
4. При согласии владелец выдаёт отдельный узкий грант: например, только запросить свободные интервалы на выбранный срок. Разрешение на общение и доступ к данным показываются раздельно.
5. Следующий подписанный запрос проходит обычные проверки. Без гранта на конкретное действие агент не получает его как поручение.

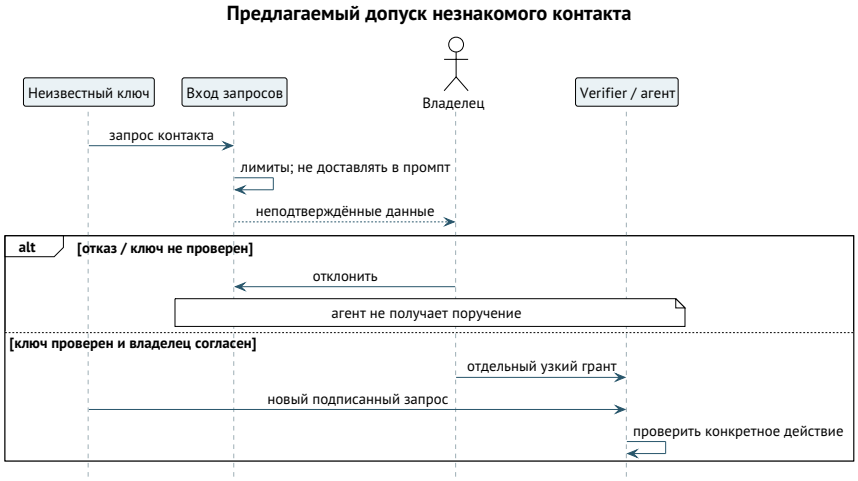


Рис. 8.1. Запрос контакта не проходит в сессию до отдельного решения

Это предложение продуктовой границы, а не уже существующий формат запроса. На хакатоне отдельный inbox запросов можно заменить ручным добавлением fingerprint, но нельзя открыть агенту все входящие и назвать это whitelist. предложено

Контроль отказа. Неизвестный отправитель повторяет запрос, меняет имя на имя близкого человека или присылает чужую цитату разрешения. Агент не запускается, календарь не читается, очередь не растёт без границ. После явного узкого гранта разрешённый запрос работает. Снятие whitelist ради успешного демо не является fallback.

9 Отозвать доступ и потерять телефон

Отзыв меняет будущий допуск. Он не стирает уже прочитанное сообщение и не отнимает сохранённую у собеседника историю. Закрытие чата, выход из аккаунта и отзыв ключа — разные операции.

1. Для обычного отзыва владелец выбирает разрешение в списке: например, право близкого человека спрашивать свободные интервалы. Подписанный отзыв публикуется в реестре.
2. Проверяющий обновляет доверенное состояние и повторяет допуск перед следующим чтением или эффектом. Неактуальная или недоступная проверка отзыва не считается подтверждением действительности гранта.
3. При потере телефона владелец использует оставшееся доверенное устройство и корневой FIDO-ключ либо заранее подготовленный резерв. Он отзывает ключ устройства и соответствующее доверие к OMEMO fingerprint.
4. Отдельно прекращаются сессии входа на сервер и обновляется состав E2EE-устройств. Отзыв подписи не равен удалению OMEMO-устройства; эти состояния должны согласоваться.
5. Новый телефон проходит новую привязку и аттестацию. Старые разрешения не восстанавливаются по имени аккаунта или просьбе в чате.

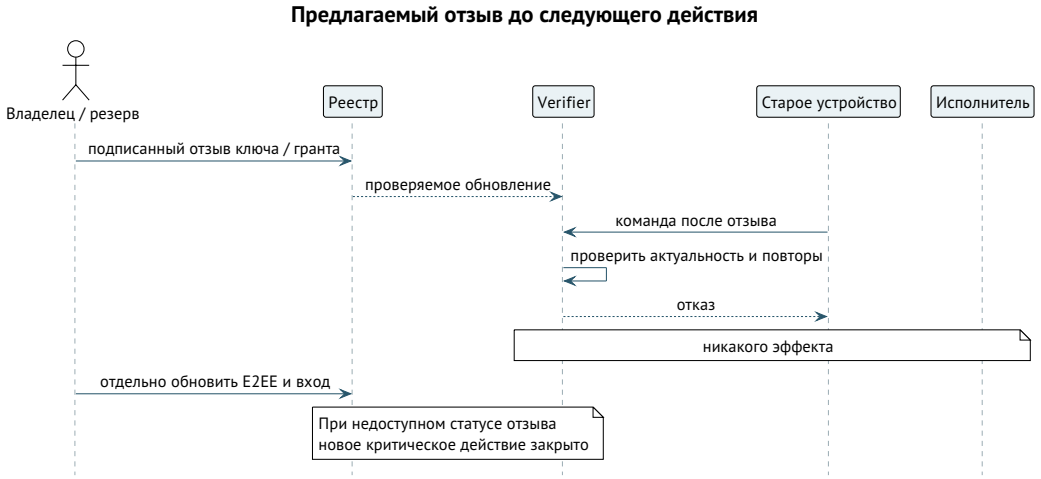


Рис. 9.1. Отзыв проверяется до нового действия, независимо от доставки сообщения

Контроль отказа. Старый телефон отправляет ранее подписанную команду после отзыва: эффекта нет. Положительный контроль — допустимое действие с оставшегося доверенного устройства и действующим грантом. При недоступном реестре критический путь закрыт; UI объясняет, что проверка не завершена, а не рисует зелёную галочку.

Нужны отдельные контракты свежести, защиты от отката, распространения отзыва и восстановления корня. Для consumer-сборки численные окна здесь не назначаются. Если потеряны телефон и единственный корневой ключ без подготовленного резерва, восстановление пока не определено. Сброс пароля провайдером не должен молча создавать новый доверенный корень. На хакатоне демонстрируется заранее подготовленная процедура, а не универсальное восстановление. открыто

10 Доверие словами пользователя

Интерфейс различает «Кто это?», «Что ему разрешено?» и «Что я подтверждаю?». Аттестация удостоверяет ключ и назначение; грант ограничивает действие; отзыв прекращает допуск. Подпись доказывает происхождение байтов, а не истинность ответа.

Свидетельство	Понятный момент в UI	Чего оно не разрешает
A0: отправителя утверждает сервер	«Личность не проверена»; запрос вне сессии	Не выдаёт права и не подтверждает критическое действие
A1: проверенное устройство или агентский ключ	«Ключ проверен» после проверки цепочки; общение по выданным правам	Не даёт права менять календарь и не доказывает решение человека
A2: человеческая подпись точного конверта	Типизированное действие внутри гранта	Не заменяет требуемое присутствие
A3: телефон показывает действие, человек подтверждает ключом	«Разрешить чтение свободного времени до указанного срока» с Face ID	Не расширяет грант и не разрешает другие действия

Matrix использует cross-signing и закреплённый master key; XMPP требует проверки OMEMO fingerprint и его аттестации. TLS, анимация Face ID и переходные исключения платформы не создают consumer-допуск. Для критического пути нужен контракт проверяемого присутствия.

10.1 Что видит сервер

При корректном E2EE и проверенных устройствах сервер хранит шифротекст содержимого, но видит адреса, связи, время, размеры и служебное состояние. Он может задержать сообщение или подать неполные сведения об устройствах. Клиент не принимает это как новую доверенную личность. Федерация этих ограничений не снимает.

Агент читает сообщение; захваченное устройство может раскрыть plaintext. Вложения требуют отдельного шифрования. Push без текста не скрывает факт уведомления. «Только шифротекст» относится к содержимому при выполненных условиях, а не ко всей информации об общении.

10.2 Подписи через границу транспорта

Закрытый список доменных меток разделяет конверты, гранты, аттестации и отзывы. Устройство использует P-256 low-S, агент — Ed25519; алгоритм и назначение проверяются точно. Форматы задаёт спецификация подписанных сообщений; продукт их не расширяет.

Вход проверяется отдельно. Логин модели — у брокера; E2EE-секреты — в crypto-store клиента; агентский ключ — у ключника; ключ человека — за key provider. Весь процесс Signer не является «лишённым секретов»: у E2EE есть своё состояние.

11 Что собираем на хакатоне

Цель — показать ограниченный полезный путь и его отказы. Не требуется закончить весь рантайм, но каждый mock виден зрителю. Следующая граница предлагается для первой команды. Реальная криптография берётся из проверенной библиотеки; собственный учебный OMEMO не строится. предложено

Реально строим и проверяем	Имитируем, готовим вручную или откладываем
Минимальный iOS-клиент: список чатов, разговор, карточка разрешения, явные состояния ошибки	Полноценный desktop-клиент: пока контрольная панель/существующий клиент без заявления совместимости Signer
E2EE-переписка двух людей и разговор с агентом на одном выбранном профиле OMEMO	Собственный серверный бренд и выбор провайдеров; все аккаунты подготовлены вручную
Один локальный XMPP-адаптер к одному harness через хост сессий	Автоматическое развёртывание станции, всех учёток и произвольных агентов
Проверка ограниченного разрешения перед чтением только свободных интервалов тестового календаря	Настоящие личные календари, платежи, удаление реальных данных
Положительный запрос, отказ на лишние поля/операции, отзыв и повтор запроса	Если общий verifier не готов — явно симулированный результат без доступа к реальным инструментам
Корневая аттестация подготовленных тестовых ключей и проверка цепочки, когда доступен совместимый модуль	Корневая церемония — ручная; автоматическое восстановление после полной потери корня отсутствует
Face ID и аппаратная подпись — только если работают точные байты и verifier	Иначе карточка помечена «симуляция подтверждения»; критический реальный эффект закрыт
Проверяемый журнал вердиктов без plaintext чувствительных данных	Push, вложения, MIX, широкий discovery и несколько моделей — после основного пути

11.1 Демо на шесть с половиной минут

Это предложенный тайминг сценария, не измеренная скорость продукта.

1. **0:00–0:45.** Два человека обмениваются сообщениями; показать E2EE и границу метаданных.
2. **0:45–1:45.** Привязать телефон к подготовленной станции: QR и SAS либо честная ручная сверка.
3. **1:45–2:30.** Попросить календарного помощника; показать отдельную личность и подготовленный профиль, назвать ручной provisioning.
4. **2:30–4:00.** Выдать узкий семейный грант. Спросить про пятницу и получить только свободные интервалы.
5. **4:00–5:00.** Попросить название встречи/удаление: отказ. Показать, что приглашение в чат не дало доступа.
6. **5:00–6:00.** Отозвать грант и повторить ранее успешный запрос: отказ; затем показать допустимый запрос собственного владельца.
7. **6:00–6:30.** Показать отмеченные mock-компоненты и следующий проверяемый этап: второй домен или mobile push.

11.2 Риски и fallback

Риск	Проверка до демонстрации	Допустимое упрощение
OMEMO-профили несовместимы	Два клиента, offline, новое устройство, подменённый fingerprint	Одна согласованная пара клиентов; plaintext не выдаётся за E2EE
Ключевой SASL не готов	Реальная аутентификация и отзыв на выбранном сервере	Ручной вход с явной маркировкой; не обещать key-based onboarding
Нет совместимого trust-core	Разрешённый запрос и отказ на изменённую цель/отзыв	Только симуляция с тестовым календарём, без реальных эффектов
iOS не получает push	Заблокированный экран, возврат из фона	Foreground-only демонстрация с объяснением ограничения
Федерация недоступна	Два домена, совпадение ключей и отказ на подмену	Один сервер; не называть это проверенной федерацией
Native session bridge теряет ход	Обрыв/повтор доставки, явная квитанция исполнения	Один заранее запущенный агент; не выдавать доставку за исполнение

12 После демо: продукт и решения

Хакатон проверяет, понимает ли человек ограниченное разрешение и получает ли полезный ответ. Для продукта нужны устойчивость и воспроизводимые гарантии на реальных устройствах, а не больше экранов. Следующий порядок работ предлагается как обратная связь в roadmap платформы. предложено

Следующий результат	Что возвращается в платформу
Совместимый Signer core и key provider	Общие векторы контракта подписанных сообщений, проверка отмены и точных байтов; утверждённый язык и ABI
XMPP-провайдер a2a	Явный контракт адресов, аудитории, повторов и квитанций; проверка двух доменов и смены OMEMO-устройств
Автоматический provisioning	Создание учётки ОС, ключа, аккаунта, профиля и сессии с восстановлением после частичного сбоя
Потеря устройства без потери контроля	Резерв корня, отзыв входа и E2EE, freshness и anti-rollback реестра; проверка offline и разделения сети
Продуктовый мобильный lifecycle	APNs без текста, background/reconnect, миграция crypto-store и история без потери границ доверия
Безопасные межвладельческие инструменты	Узкие API данных вместо доступа модели ко всему; тесты области, аудит без лишнего содержания
Работа на разных станциях	Контракты сессий и launch-политик, явное владение и остановка; брокер логинов остаётся отдельным владельцем секретов

Готовность подтверждается сквозными испытаниями: допустимый семейный запрос проходит; расширение прав, повтор, отмена и отзыв не создают эффекта. Для каждого нового допускающего правила нужен контроль, который удаляет именно его и воспроизводит запрещённый исход. Две реализации, одинаково принимающие ошибочный запрос, не заменяют нормативное ожидание.

12.1 Вопросы оператору

1. Какую подачу и название выбираем? Для кого первый сценарий: одного владельца, семьи или команды?
2. Достаточно ли iOS и desktop-панели? Когда обязательны Android и полноценный desktop-клиент?
3. Какие сервер и библиотеки квалифицируем? Нужны ли component-стык и два домена уже в демо; кто обслуживает сервер?
4. Что подтверждает QR/SAS, как удостоверяется root и готовится резерв? Каков контракт присутствия и A3 на desktop?
5. Каковы окна свежести, хранения повторов и распространения отзыва? Что показывает UI при недоступной проверке?
6. Кто может запросить контакт, как ограничиваем спам и когда открываем discovery?